

CloudTrail & Audit Logging

BaseStack Academy · AWS Cloud Accelerator

IAM & Security

Cohort 1

Beginner-Friendly

SAA-C03 Aligned

basestack.academy

 **WHO**

IAM Principal

 **WHAT**

API Action

 **WHEN**

Timestamp

 **WHERE**

Source IP / Region

CloudTrail records every API call

 **Delivered to S3 Bucket**

1 Overview — Why Audit Logging Is Non-Negotiable

FOUNDATION

2 Key Concepts — Definitions & Vocabulary

CORE KNOWLEDGE

3 CloudTrail Event Types — Management, Data & Insights

DEEPER LEARNING

4 How It Works — Step by Step

MECHANICS

5 Technical Deep Dive — Event Structure & Log Integrity

ADVANCED DETAIL

6 Architecture & Visual Model

VISUAL

7 Real-World Nigerian Scenario

CONTEXT

8 Common Mistakes & Exam Traps

EXAM PREP



Overview — Why Audit Logging Is Non-Negotiable

Every action taken in your AWS environment — every API call, every console login, every resource creation or deletion — leaves a digital fingerprint. AWS CloudTrail is the service that captures those fingerprints and stores them as tamper-evident log records.

Without CloudTrail, you have no way to answer critical questions: Who deleted that S3 bucket? Which IAM user changed the security group rule? What IP address was used to log in before the data breach? CloudTrail turns your AWS account from a black box into a fully auditable system.

In 2022, a major cloud data breach was traced to a single misconfigured IAM role. The forensic investigation took weeks longer than necessary because the organisation had not enabled CloudTrail in all regions. The evidence existed — but was not captured. That mistake cost millions of dollars and triggered regulatory fines.

WHY NOW?

The Central Bank of Nigeria (CBN) Cybersecurity Framework requires financial institutions to maintain audit trails of all system activity.

ISO 27001 — the global information security standard — explicitly requires evidence of access and activity logging. CloudTrail is AWS's implementation of this requirement.

SAA-C03 Domain 2 (Secure Architectures) and Domain 4 (Cost-Optimised Architectures) both test your ability to design CloudTrail solutions correctly.

Beginner Note

Think of CloudTrail as CCTV for your AWS account. Every action is recorded — who did it, what they did, when, from which IP, and what the result was. You may not watch the footage every day, but when something goes wrong, you need it to exist.



Key Concepts — Know These Definitions

 *Study tip: Say each definition aloud — spoken repetition builds memory 3× faster than reading alone.*

AWS CloudTrail

A regional AWS service that continuously records all API calls and account activity across your AWS infrastructure — via the console, CLI, SDK, or other AWS services — and stores them as JSON log files in an S3 bucket.

Event History

A free, always-on view of the last 90 days of management events in the CloudTrail console. It requires no configuration, but it is NOT a substitute for a proper Trail — it doesn't persist beyond 90 days and cannot alert you.

Trail

A configuration in CloudTrail that defines WHERE to deliver event logs (S3 bucket, CloudWatch Logs), WHICH regions to capture, and WHICH event types to include. Without a Trail, only the last 90 days of management events are retained.

S3 Bucket (Log Destination)

CloudTrail delivers log files to an S3 bucket you specify. The bucket must have a bucket policy granting CloudTrail permission to write. Log files are compressed (.gz), delivered within ~15 minutes of the event.

CloudTrail Event

A single JSON record of one API call or AWS action. Every event contains: who (principal ARN), what (event name), when (timestamp), where (source IP, region), and the outcome (success/failure).

CloudTrail Lake

A managed event data lake that lets you run SQL queries against your CloudTrail events — without extracting them from S3. Supports multi-account, multi-region queries and retains data for up to 7 years.



CloudTrail Event Types — What Gets Recorded

CloudTrail captures three distinct categories of events. Understanding them is essential — both for the exam and for designing cost-effective logging architectures.



Management Events

Control Plane Operations

✅ Enabled by default in all Trails

Records operations that configure or manage AWS resources — the 'control plane'. Examples include:

- CreateBucket, DeleteBucket
- AttachRolePolicy, CreateUser
- RunInstances, TerminateInstances
- AuthorizeSecurityGroupIngress
- ConsoleLogin



SAA-C03: Management events are what most governance and compliance solutions rely on. Default Trail captures these.



Data Events

Data Plane Operations — High Volume

⚠️ NOT enabled by default — must be explicitly turned on

Records object-level operations on resources — the 'data plane'. Examples:

- S3: GetObject, PutObject, DeleteObject
- Lambda: InvokeFunction
- DynamoDB: GetItem, PutItem
- Cognito: InitiateAuth

Warning: S3 data events can generate millions of log entries per day. Enabling them costs money.



SAA-C03: Questions often test whether you know data events are OFF by default. Required for forensics on S3 data access.



CloudTrail Insights

Anomaly Detection — Optional Add-On

💰 Additional cost — not included in standard Trail pricing

Uses machine learning to detect unusual API activity patterns. Triggers when:

- Unusual spike in write API call volume
- Unusual burst of error rate on API calls
- Activity patterns deviating from the established baseline

Delivers Insights events to the same S3 bucket as normal events.



SAA-C03: Insights ≠ standard event logging. It is an anomaly detection layer. Requires standard Management Events as a prerequisite.



Key Concepts (Continued) — Integrations & Controls

Concepts Summary

CloudTrail integrates with four other AWS services to create a complete detection and response pipeline.

✓ CloudWatch Logs Integration

✓ EventBridge Integration

✓ Log File Integrity Validation

✓ Multi-Region Trail

✓ Organisation Trail

✓ CloudTrail Lake



How Integrations Work

CloudWatch Logs →

CloudTrail streams events to a CloudWatch Logs log group. You create Metric Filters on specific events (e.g., root account login) and CloudWatch Alarms that notify SNS when those filters match. This enables real-time alerting.

EventBridge →

CloudTrail events trigger EventBridge rules, which can invoke Lambda, send to SQS, or start Step Functions. Use case: auto-revoke an IAM key the moment an unauthorized IP uses it.

Log File Integrity →

Every log file is hashed (SHA-256). CloudTrail creates daily digest files that chain together file hashes. You can use the AWS CLI to validate that no log file was modified, deleted, or forged after delivery.

Multi-Region Trail →

A single Trail configured to capture events from ALL regions simultaneously. Without this, a single-region Trail misses API calls made in other regions — a common security blind spot.



How It Works — Step by Step

1

Create a Trail & Configure Delivery

In the CloudTrail console, create a new Trail. Give it a name and choose the S3 bucket where logs will be delivered. Critically — select 'Apply trail to all regions' to ensure you capture events across every AWS region. Optionally enable CloudWatch Logs delivery to stream events for real-time monitoring. You can also enable log file integrity validation here — this is a one-checkbox step that provides forensic-grade tamper detection for all future log files.

2

Choose Event Types to Capture

Management Events are enabled by default. Decide whether you need Data Events — and if so, for which services. For a production fintech, you would enable S3 Data Events to capture every object access. Enable Lambda Data Events if you need visibility into function invocations. Be deliberate — Data Events can generate very high log volumes and cost. If you only need anomaly detection on top of management events, enable CloudTrail Insights rather than blanket data event logging.

3

Events Flow Through the Pipeline

When any principal makes an API call in a member account, CloudTrail captures it within ~15 minutes and writes a compressed JSON log file to your S3 bucket. The folder structure is: BucketName/AWSLogs/AccountID/CloudTrail/Region/YYYY/MM/DD/. Simultaneously, if CloudWatch Logs is configured, the event streams there in near real-time. CloudWatch Metric Filters evaluate the incoming stream and trigger Alarms when specific patterns match — for example: root account login, security group changes, or S3 bucket policy modifications.

Technical Deep Dive — Event Structure & Log Integrity

CloudTrail Event Record (JSON)

```
{
  "eventVersion": "1.08",
  "userIdentity": {
    "type": "IAMUser",
    "arn": "arn:aws:iam::123456789:user/developer1",
    "userName": "developer1"
  },
  "eventTime": "2024-09-15T14:32:01Z",
  "eventSource": "s3.amazonaws.com",
  "eventName": "DeleteBucket",
  "awsRegion": "eu-west-1",
  "sourceIPAddress": "197.210.52.8",
  "requestParameters": {
    "bucketName": "fintech-customer-data"
  },
  "responseElements": null
}
```

Field-by-Field Explanation

userIdentity

WHO made the call — the full IAM principal ARN, account ID, session context, and assumed-role information if applicable.

eventTime

WHEN — ISO 8601 UTC timestamp. Used for timeline reconstruction during incident response.

eventName

WHAT — the specific API call (DeleteBucket, PutObject, RunInstances). This is your primary filter for alert rules.

sourceIPAddress

WHERE from — the originating IP. If this is an unexpected country or ASN, it's a red flag. CBN requires logging source IPs for all privileged actions.

eventSource

WHICH service received the call — s3.amazonaws.com, ec2.amazonaws.com, iam.amazonaws.com, etc.



Log File Integrity Validation

SHA-256 hash of each log file is stored in a daily digest file, cryptographically signed by AWS. Run: `aws cloudtrail validate-logs` to verify no file was modified or deleted.



Architecture & Visual Model — CloudTrail Pipeline

EVENT SOURCES



Console Login



AWS CLI



SDK / API



AWS Services



Cross-Account



AWS CloudTrail — Captures ALL API Calls & Account Activity

DELIVERY DESTINATIONS



S3 Bucket

Primary store
Retain 1–7 years
Compressed JSON

Required for all Trails



CloudWatch Logs

Near real-time stream
Metric Filters
Alarms → SNS → PagerDuty

Enables alerting



EventBridge

Event-driven rules
Trigger Lambda
Auto-remediation

Enables automation



CloudTrail Lake

SQL queries
Up to 7 year retention
Multi-account queries

Advanced analytics

Alert Pipeline: CloudTrail → CloudWatch Logs → Metric Filter → Alarm → SNS Topic → Email / PagerDuty / Slack



Real-World Nigerian Scenario — Kuda-Style Neobank Security Incident

SCENARIO:

A Nigerian neobank — modelled on Kuda's architecture — suffers a suspected insider data exfiltration incident. A junior backend developer's IAM credentials were reportedly stolen via a phishing email. The security team must determine exactly what data was accessed, from where, and whether any infrastructure was modified. They have 48 hours to report to the CBN under the incident disclosure timeline.



CloudTrail Investigation Timeline

Hour 0

Incident Detected

The SIEM (Splunk) fires an alert at 02:14 WAT: unusual spike in s3:GetObject calls from an IP address registered in Côte d'Ivoire. The production S3 bucket contains PII — customer KYC documents.

Hour 1

CloudTrail Query

Security team queries CloudTrail Lake: `SELECT eventTime, userIdentity.userName, eventName, sourceIPAddress, requestParameters FROM cloudtrail_events WHERE eventTime > '2024-09-15T00:00:00Z' AND sourceIPAddress = '41.184.x.x' ORDER BY eventTime`. Returns 847 GetObject calls over 3 hours.

Hour 2

Scope Assessment

CloudTrail reveals: 847 S3 objects accessed (customer KYC PDFs). 2 IAM Access Key creations under the compromised user (attacker created backup access). 1 CloudTrail StopLogging attempt — BLOCKED by the organisation's root SCP (from Day 3). No EC2 changes. No RDS access.

Hour 6

Containment & Evidence

Team runs `aws cloudtrail validate-logs` — all log files pass SHA-256 integrity check. Logs are admissible as forensic evidence. CBN report filed with exact timestamps, source IPs, and list of affected records — pulled directly from CloudTrail events.



Discussion: What THREE CloudTrail configurations must have been in place BEFORE this incident for the investigation to succeed? (Hint: event type, log integrity, and region coverage.)



Common Mistakes & Exam Traps

● These are the most common SAA-C03 exam errors on this topic — every one costs marks.



TRAP 1: Event History ≠ a Trail — and it expires after 90 days

CloudTrail Event History is free and always on — but it only covers management events, only shows the last 90 days, and cannot trigger alerts. A company that relies only on Event History and doesn't create a Trail will lose all evidence of events older than 3 months. Exam questions love this distinction: 'which service would allow review of API activity from 6 months ago?' — you need a Trail with an S3 bucket.



TRAP 2: Data Events are OFF by default and cost extra

Management events are captured automatically. Data events — S3 GetObject, Lambda Invoke, DynamoDB GetItem — are NOT. If an exam question asks 'how would you detect which IAM user downloaded specific S3 objects?' the answer requires Data Events to be explicitly enabled on that Trail. This is a very common distractor — candidates assume all activity is captured by default.



TRAP 3: CloudTrail logs are NOT real-time — there is a ~15 minute delay

CloudTrail delivers log files to S3 within approximately 15 minutes of the event. This is by design — it is NOT a streaming service. For near-real-time detection, you integrate CloudTrail with CloudWatch Logs (streamed more quickly) or EventBridge. If an exam option says 'use CloudTrail to immediately detect' something, that option is likely wrong — CloudTrail detects, but not immediately.



TRAP 4: CloudTrail vs CloudWatch — they answer different questions

CloudTrail answers: WHO did WHAT to WHICH resource, WHEN and from WHERE. CloudWatch answers: HOW IS the resource performing right now — CPU, memory, latency, error rates. A common exam distractor will use one where the other is correct. 'Monitor for unusual IAM activity' → CloudTrail. 'Alert when EC2 CPU exceeds 80%' → CloudWatch.



TRAP 5: Global service events must be explicitly included — and only in one region

IAM, STS, and CloudFront are global services. Their events are logged only in us-east-1 by default. If your Trail is single-region (in eu-west-1), you will MISS all IAM API calls unless you explicitly enable 'Include global service events' on your Trail. Multi-region Trails automatically handle this — another reason to always prefer multi-region trails.



Question

A security engineer at a Lagos fintech company needs to ensure all AWS API activity across 12 accounts in an AWS Organisation is captured, stored for 3 years, and triggers an automated alert whenever the root user logs in to any account. Which combination of configurations meets ALL requirements? (Select TWO)

A

Enable CloudTrail Event History in each account. Enable root account login notifications in IAM. Store event history exports in S3 manually.

Event History only retains 90 days (not 3 years), requires per-account setup (not centralized), and cannot trigger automated alerts.

B

Create an Organization Trail in the management account with multi-region enabled. Deliver logs to a central S3 bucket with a 3-year lifecycle policy.

✓ CORRECT

Correct. An Organisation Trail automatically covers all 12 accounts from one configuration. Multi-region captures all activity. S3 lifecycle policy handles 3-year retention.

C

Enable CloudTrail Insights in each member account to detect root login anomalies.

Insights detects unusual API volumes — it is not a standard event capture mechanism and does not specifically detect or alert on root logins.

D

Create a CloudWatch Logs metric filter for the organisation trail that matches root account ConsoleLogin events, and configure a CloudWatch Alarm to publish to SNS.

✓ CORRECT

Correct. This is the standard pattern for root login alerting: CloudTrail → CloudWatch Logs → Metric Filter (eventName=ConsoleLogin AND userType=Root) → Alarm → SNS.

💡 Key Takeaways — What You Learned Today

CloudTrail & Audit Logging

✅ Concepts Covered

- ✓ CloudTrail records WHO, WHAT, WHEN, WHERE for every API call
- ✓ Event History — 90 days free; Trails — persist to S3 indefinitely
- ✓ 3 event types: Management (default), Data (opt-in), Insights (ML anomaly)
- ✓ Log File Integrity Validation — SHA-256 forensic-grade tamper detection
- ✓ Multi-Region Trail — capture all regions with one configuration
- ✓ Organisation Trail — covers all accounts from management account
- ✓ CloudWatch Logs → Metric Filter → Alarm → SNS for real-time alerting
- ✓ CloudTrail ≠ CloudWatch: audit vs. performance monitoring
- ✓ Global service events (IAM, STS) only captured in us-east-1 by default

📋 Before Next Class

1. Review all concepts without notes — active recall first
2. Complete the console lab: create a multi-region Trail, point it to S3, enable CloudWatch Logs
3. Create a CloudWatch Metric Filter for root login events and wire it to an SNS alert
4. Enable S3 Data Events on your Trail and run an `s3:GetObject` — verify it appears in CloudTrail
5. Re-read the 5 exam traps — write each one out by hand
6. Post your Trail screenshot on the WhatsApp group — confirm which event types you enabled



Further Resources & Reading

Go deeper with these official AWS and industry resources:



AWS CloudTrail User Guide

OFFICIAL DOCS

<https://docs.aws.amazon.com/awscloudtrail/latest/userguide/>

Complete reference for Trail creation, event types, log file format, multi-region configuration, and integrity validation. The authoritative starting point for any CloudTrail implementation.



CloudTrail Event Reference — All Event Names

REFERENCE

<https://docs.aws.amazon.com/awscloudtrail/latest/userguide/cloudtrail-event-reference.html>

Full catalogue of every AWS service event name. Use this to build precise Metric Filters and EventBridge rules. Bookmark it — you will reference this constantly in real work.



AWS Security Hub — CIS AWS Foundations Benchmark

COMPLIANCE

<https://docs.aws.amazon.com/securityhub/latest/userguide/securityhub-cis-controls.html>

CIS Benchmark includes specific controls around CloudTrail (3.x controls). Covering: multi-region trails, log file integrity, S3 bucket logging, CloudWatch alarms for root login and security group changes.



SAA-C03 Exam Guide — Domain 2 & Domain 4

EXAM PREP

https://d1.awsstatic.com/training-and-certification/docs-sa-assoc/AWS-Certified-Solutions-Architect-Associate_Exam-Guide.pdf

Download this PDF. Domain 2 covers security monitoring (CloudTrail, GuardDuty, Security Hub). Domain 4 covers cost-optimised architectures — CloudTrail Lake vs S3 cost trade-offs appear here.



AWS re:Invent — CloudTrail & Security Observability

VIDEO

https://www.youtube.com/results?search_query=aws+reinvent+cloudtrail+security+logging

Search 'AWS re:Invent CloudTrail' — SEC305 and SEC401 sessions cover threat detection pipelines built on CloudTrail + GuardDuty + Security Hub. Real enterprise architectures from AWS customers.



Homework: Read at least ONE resource above before next class. Post what you learned on the WhatsApp group.



Week 2 · Day 4 Complete

CloudTrail & Audit Logging

IAM & Security

Next: Hands-on Console Lab →

basestack.academy · Cohort 1 · AWS Cloud Accelerator